

# Information Security

Course Code: CACS459

BCA 8th

# Unit 1

## Overview of Computer Security

1.1 Computer Security Concepts

1.2 Computer Security, Information Security, Network Security

1.3 Threats, Attacks and Assets

1.4 Security Requirements

1.5 Security Design Principles

1.6 Attack Surfaces and Attack Trees

1.7 Computer Security Strategy

# Unit 1

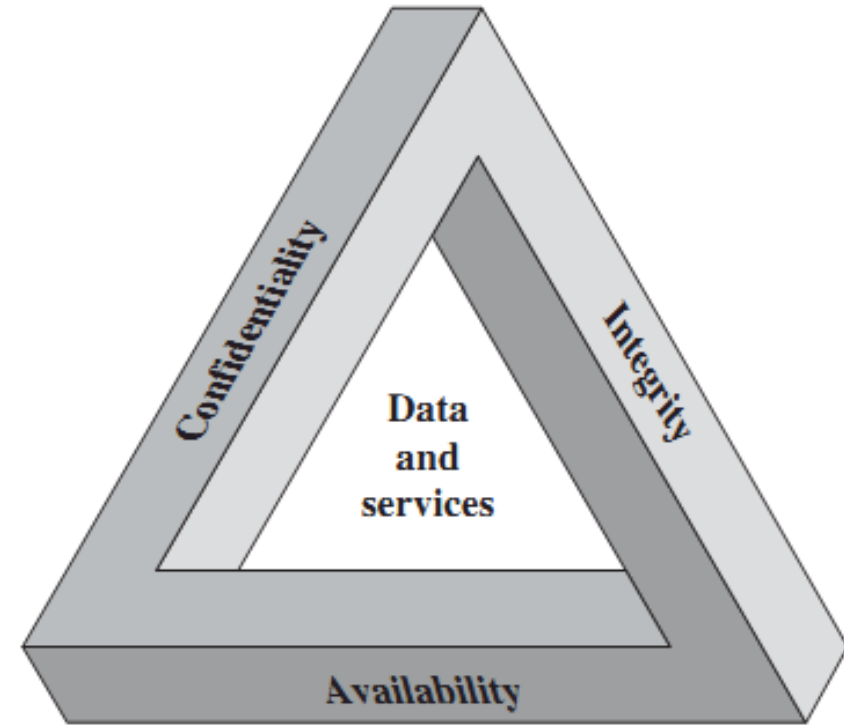
## 1.1 Computer Security Concepts

**COMPUTER SECURITY:** The protection afforded to an automated information system in order to attain the applicable objectives of preserving the integrity, availability, and confidentiality of information system resources (includes hardware, software, firmware, information/data, and telecommunications).

This definition introduces three key objectives that are at the heart of computer security:

- **Confidentiality**
- **Integrity**
- **Availability**

- **Confidentiality:** Data confidentiality, Privacy
- **Integrity:** Data integrity, System integrity
- **Availability:** Information access



**Figure 1.1** The Security Requirements Triad

Although the use of the CIA triad to define security objectives is well established, some in the security field feel that additional concepts are needed to present a complete picture. Two of the most commonly mentioned are as follows:

- ❖ **Authenticity:** The property of being genuine and being able to be verified and trusted; confidence in the validity of a transmission, a message, or message originator. This means verifying that users are who they say they are and that each input arriving at the system came from a trusted source.
- ❖ **Accountability:** The security goal that generates the requirement for actions of an entity to be traced uniquely to that entity. This supports nonrepudiation, deterrence, fault isolation, intrusion detection and prevention, and after-action recovery and legal action. Because truly secure systems are not yet an achievable goal, we must be able to trace a security breach to a responsible party. Systems must keep records of their activities to permit later forensic analysis to trace security breaches or to aid in transaction disputes.

# 1.2 Computer Security, Network Security and Information Security

| Computer Security                                                     | Information Security                                                                                                                                                                                                                                                                                                                       | Network Security                                                                                                         |
|-----------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------|
| a) Deals with securing a standalone computer's hardware and software. | a) Protects both physical and digital data from unauthorized access, usage, disclosure, disruption, modification, inspection, destruction, and recording.                                                                                                                                                                                  | a) Protects any data sent through devices in your network to ensure that the information isn't modified not intercepted. |
|                                                                       | b) CIA Triad is the information security model is used when managing data.                                                                                                                                                                                                                                                                 | b) It protects the organization's IT infrastructure against threats such as;<br>viruses, spyware, hackers, etc.          |
|                                                                       | <ul style="list-style-type: none"><li>• Confidentiality. Only authorized parties have access to data.</li><li>• Integrity. Data is accurate and trustworthy. It should not be modified or compromised in any way by any unauthorized parties.</li><li>• Availability. Authorized parties can access the information when needed.</li></ul> |                                                                                                                          |

# Security Breaches Terminology

- Exposure: a form of possible loss or harm
- Vulnerability: a weakness in the system
- Attack
- Threats: Human attacks, natural disasters, errors
- Control: a protective measure
- Assets: data

# 1.2 Threats, Attacks and Assets

❖ **Threat:** A potential for violation of security, which exists when there is a circumstance, capability, action, or event that could breach security and cause harm. That is, a threat is a possible danger that might exploit a vulnerability.

Some common threats in information security include:

1. Malware : a type of software designed to damage or disrupt computer systems.
2. Phishing: a technique used by attackers to trick people into revealing sensitive information.
3. Social Engineering: manipulating people into divulging sensitive information



# 1.2 Threats, Attacks and Assets

❖ **Attack:** An attack is an intentional action that exploits a vulnerability in the information system, causing harm to the system's confidentiality, integrity, or availability.

Consequences of attacks:

Loss of data, reputational damage, financial losses etc.

# 1.2 Threats, Attacks and Assets

- **Assets:** Assets refer to any valuable resources that an organization possesses, including data, software, hardware, and intellectual property.

Some important assets in information security include;

1. Data
2. Software
3. Hardware
4. Intellectual property

# 1.4 Security Requirements

Information security requires a set of security requirements that ensure the confidentiality, integrity, and availability of sensitive information.

Such requirements can vary depending upon the organization, its assets, and the regulatory environment in which it operates.

# 1.4 Security Requirements

Common security requirements in information security are;

1. **Access Control** : ensures that only authorized users have access to sensitive information
2. **Encryption** : ensures that sensitive data is protected from unauthorized access by encrypting it with a secret key. Encryption can be used to protect data at rest, in transit, or in use.
3. **Authentication**: Authentication is a security requirement that ensures that users are who they claim to be. This can be achieved through various methods, including passwords, biometrics, and two-factor authentication.

# 1.4 Security Requirements

4. **Authorization:** ensures that users have the necessary permissions to access sensitive information. This can be achieved through role-based access control, attribute-based access control, or other methods.

5. **Audit and Monitoring:** ensures that all activity on the information system is logged and monitored for suspicious activity. This can include intrusion detection systems, security information and event management (SIEM) tools, and other monitoring solutions.

6. **Incident Response:** ensures that the organization is prepared to respond to security incidents, such as data breaches or cyber attacks. This can include incident response plans, incident response teams, and other measures.

# 1.4 Security Requirements

7. **Physical Security** : ensures that the physical environment where sensitive information is stored is protected from unauthorized access or damage. This can include measures such as access control systems, surveillance cameras, and other physical security measures.

# 1.5 Security Design Principles

Security design principles are fundamental guidelines for building secure information systems. They provide a framework for creating secure architectures and ensuring that sensitive information is protected from unauthorized access, theft, or loss.

# 1.5 Security Design Principles

1. Defense in Depth
2. Least privilege
3. Fail-Safe Defaults
4. Separation of Duties
5. Defense against attacks
6. Secure by design
7. Open Design
8. Separation of Privilege
9. Least Common Mechanism
10. Psychological Acceptability





**Fig: Common Security Design Principles**

# 1.5 Security Design Principles

1. **Defense in depth** : a strategy that leverages multiple security measures to protect an organization's assets. The thinking is that if one line of defense is compromised, additional layers exist as a backup to ensure that threats are stopped along the way.
2. **Least Privilege**: This principle states that a user should only have those privileges that need to complete his task. Its primary function is to control the assignment of rights granted to the user, not the identity of the user. This means that if the boss demands root access to a UNIX system that you administer, he/she should not be given that right unless he/she has a task that requires such level of access.

# 1.5 Security Design Principles

3. **Fail Safe Defaults:** states that the default configuration of a system should have a conservative protection scheme.

**Example:** If we will add a new user to an operating system, the default group of the user should have fewer access rights to files and services.

4. **Separation of Duties:** This principle states that a system should grant access permission based on more than one condition being satisfied. This principle may also be restrictive because it limits access to system entities. Thus before privilege is granted more than two verification should be performed.

# 1.5 Security Design Principles

5. **Defense against Attacks:** This principle states that the preventive measures to be executed to save the system from attacks.

6. **Secure by design:** This principle states that the system should be developed as free of vulnerabilities to attack as possible through such measures as continuous testing, authentication safeguards.

# 1.5 Security Design Principles

7. **Open Design:** This principle states that the security of a mechanism should not depend on the secrecy of its design or implementation. It suggests that complexity does not add security. This principle is the opposite of the approach known as "security through obscurity." This principle not only applies to information such as passwords or cryptographic systems but also to other computer security related operations.

# 1.5 Security Design Principles

8. **Separation of Privilege** : a system should grant access permission based on more than on more than one condition being satisfied.

9. **Least Common Mechanism**: It states that in systems with multiple users, the mechanisms allowing resources shared by more than one user should as much as possible. This principle may also be restrictive because it limits the sharing of resources.

# 1.5 Security Design Principles

10. **Psychological Acceptability:** This principle states that a security mechanism should not make the resource more complicated to access if the security mechanisms were not present. The psychological acceptability principle recognizes the human element in computer security. If security-related software or computer systems are too complicated to configure, maintain, or operate, the user will not employ the necessary security mechanisms. **Example:** When we enter a wrong password, the system should only tell us that the user id or password was incorrect. It should not tell us that only the password was wrong as this gives the attacker information.

# 1.6 Attack Surfaces and Attack Trees

## **Attack Surfaces**

Attack surface is the total sum of separate points which can be easily accessible for a hacker or attacker. If a hacker wants to access the system he has to do by scanning the target's attack surface. These attack surface has three categories they are network, software, and physical attack surface. These attack surface can be reduced by reducing the codes.



# 1.6 Attack Surfaces and Attack Trees

## Types of Attack Surfaces:

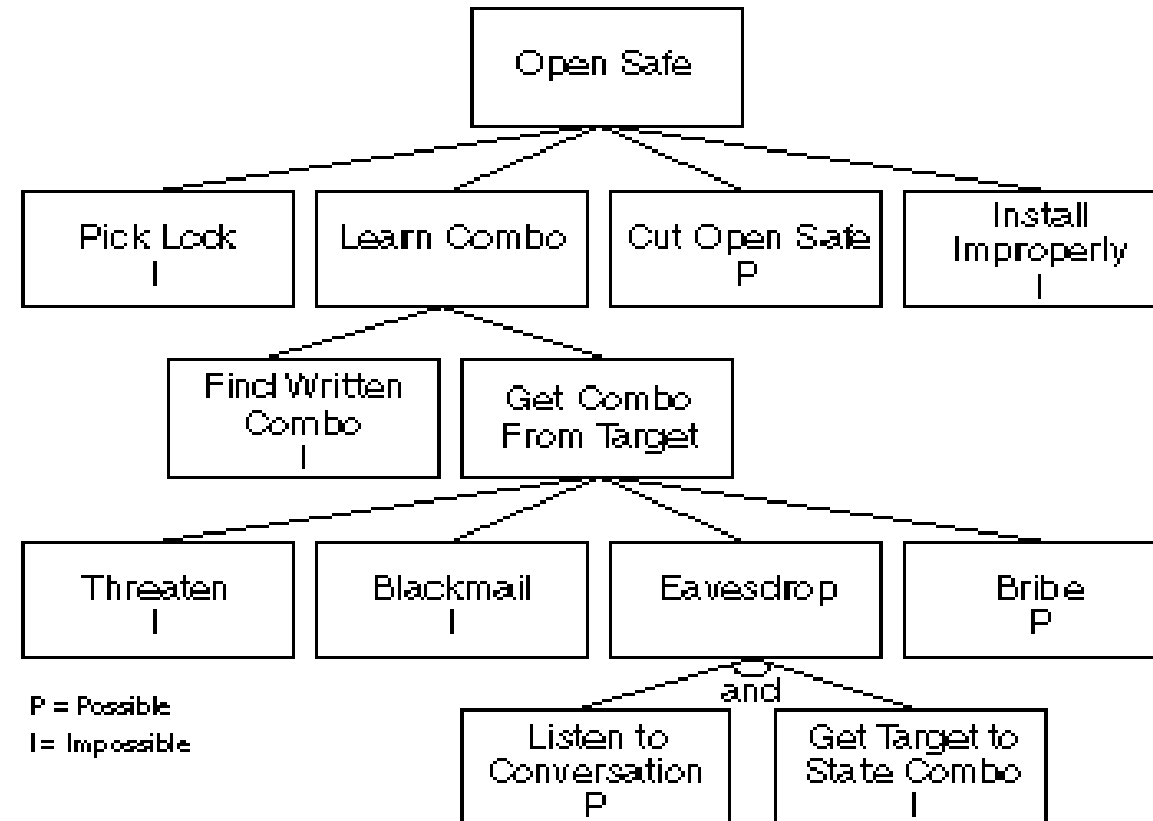
- **Passive:** A passive attack surface refers to a system or network that has either been compromised by an attacker (i.e., the individual is already providing resources) or has not yet been compromised by an attacker, but provides its own security services (e.g., password authentication).
- **Active:** An active attack surface includes a system or network in which an attacker may directly interact with elements of the infrastructure, such as users and devices. Active attacks on a target are typically performed during reconnaissance and pre-attack phases when more information about the target is desired before initiating any destructive actions.

# 1.6 Attack Surfaces and Attack Trees

## Attack Trees

Attack trees are conceptual diagrams showing how an asset, or target, might be attacked. Attack trees have been used in a variety of applications. In the field of information technology, they have been used **to describe threats on computer systems and possible attacks to realize those threats.**

# 1.6 Attack Surfaces and Attack Trees



**Fig: Attack Tree**

## 1.7 Computer Security Strategy

**A plan that involves selecting and implementing best practices to protect a business from internal and external threats.** This strategy also establishes a baseline for a company's security program which allows it to continuously adapt to emerging threats and risks.

# Assignment

## Theory:

- a) What is Information Security? List and briefly define fundamental security design principle.
- b) Describe about Attack surface and Attack tree.
- c) Explain three principles of Information Security.

or

Explain about CIA Triad.